Industrial Security (Bachelor)

Solution Sheet – Section 03

Industrial Network Architectures

Note. Model answers below. Mark for *defensible design choices* more than for matching the sample text word-for-word. Rubric hints in italics at the end of each solution.

Solution

Exercise 3.1 – Place the Assets on Purdue Levels. Hirschmann RSP35 switch: infrastructure of L1/L2 (network fabric, not a level itself). S7-1500 capper PLC: L1. InTouch HMI: L2. PI Historian: lives at L3, with a *replica* in the iDMZ (L3.5). WSUS: L3.5 (iDMZ patch broker). mGuard vendor jump host: L3.5. SAP S/4HANA: L5. Tofino in front of the SIS: infrastructure inside the safety zone; the SIS controller is logically L1 but in a separate zone from the BPCS. Wi-Fi torque wrench: L2 telemetry, but the access network sits in a dedicated wireless segment that lands in the iDMZ before crossing into L2. M365 mail tenant: L5 (cloud-hosted enterprise). Ambiguous: (a) the historian, because the question whether "the historian" means the live one (L3) or the replica (L3.5) is exactly what the iDMZ design forces you to answer; (b) the Wi-Fi torque wrench, because wireless data origin and aggregation are at different levels; (c) the Tofino, because firewalls are infrastructure and do not occupy a level themselves but enforce a conduit. *Rubric: full marks if every L1/L2/L5 placement is correct, the iDMZ broker pattern is recognised, and at least two of the three ambiguities are named with a sound reason.*

Solution

Exercise 3.2 – Vendor PLC Firmware Update. Flow: vendor laptop → Internet → corporate VPN/identity provider → iDMZ vendor jump host (mGuard, Cisco DUO MFA) → L3 engineering workstation (with the signed firmware staged from a quarantined transfer share) → Tofino in front of the PLC → L1 PLC.

Three rules (illustrative, time-windowed to the outage):

1. Corp → iDMZ jump host: TCP/443 (HTTPS) and TCP/3389 (RDP) from the vendor's identity-bound source group only, MFA required, window 08:00–12:00 of outage day.
2. iDMZ jump host → L3 engineering workstation: TCP/3389 with session recording, same window.
3. L3 engineering workstation → L1 PLC via Tofino: vendor-specific engineering protocol (e.g. S7comm-plus on TCP/102) with a function-code allowlist limited to "firmware download", same window. All other windows: deny.

Logging/attestation: capture the SHA-256 hash of the firmware image on the engineering workstation, write it to the SIEM, and require the vendor to counter-sign that the running hash on the PLC matches after reboot (or use the controller's signed-firmware attestation feature if present, e.g. Siemens SIMATIC "protected" mode with code-signing). The single control preventing direct vendor-laptop-to-PLC contact is the iDMZ jump host: the vendor never holds a route to L1. *Rubric: rules must be time-bounded, source-restricted, and stepwise across the iDMZ; attestation must be falsifiable, not just "check the log".*

Solution

Exercise 3.3 – Flat-to-Segmented Migration. Step 1 – Passive discovery. Drop a Garland TAP or Hirschmann SPAN onto the core and run Nozomi/Claroty/Dragos in listen-only mode for two to four weeks to baseline every flow. No downtime, fully reversible (remove

the TAP). **Step 2 – Stand up the iDMZ alongside.** Install a second firewall pair (e.g. Fortinet 60F + 100F) and an iDMZ subnet for the historian replica, WSUS, AV relay, and vendor jump host. Replication runs in parallel; no traffic is cut yet. Downtime: zero. Rollback: leave the iDMZ idle. **Step 3 – Reroute corporate consumers.** Switch BI tools and SAP to read from the iDMZ replica instead of the live historian; close the L3→L5 direct path on the ASA. Downtime: minutes per consumer; rollback: re-open the ASA rule. **Step 4 – Subnet split inside OT.** Renumber the flat /22 into per-line VLANs and per-zone subnets behind the Tofino/ISA pair, with deny-by-default ACLs. Sequence one line at a time during planned outages. Downtime: hours per line; rollback: keep the old flat VLAN configured but shutdown until needed.
Riskiest step: Step 4. Renumbering live PLCs breaks every hard-coded peer (HMI, MES, peer-PLC, vendor remote) at once; one missed dependency stops a line. Always pair it with a frozen change window, a printed roll-back plan, and an on-site OEM engineer. *Rubric: order must be passive-first, additive-second, cutover-last; the renumbering step must be flagged as riskiest with a concrete dependency reason.*

Solution

Exercise 3.4 – Diode vs. Stateful Firewall. *Direction:* the diode enforces direction in hardware (no receive optics on the high side); a stateful firewall depends on software correctness and a clean rule set. *Protocol:* the diode needs a vendor proxy per protocol (Owl/Waterfall historian connector, OPC UA replicator, syslog forwarder) and cannot carry interactive sessions; the firewall passes anything its rule set permits, including bidirectional ACKs for TCP. *Operational cost:* a diode is five-figure euros, deployed once, almost zero day-to-day admin; a firewall is cheaper to buy but carries a continuous rule-review burden. *Forensic value:* the diode trivially proves no inbound flow occurred; the firewall requires log review to prove the same.
Diode is right when the historian belongs to a high-consequence site (nuclear, defence, upstream pipeline SCADA) and the corporate side must never be able to write back – the audit story alone justifies the price. *Stateful firewall is right* for an ordinary discrete-manufacturing plant where the reporting database also pushes back tag-renames or write-back of laboratory reference values during shift handover – a diode would break that workflow, and the residual risk is acceptable with deny-by-default rules plus a Nozomi sensor on the L3 side. *Rubric: the candidate must name at least three of the four axes correctly and justify each scenario with a concrete reason beyond "more secure".*

Solution

Exercise 3.5 – Spot the Segmentation Failure. (a) Both ends of the trunk in `dynamic auto` with native VLAN 1 is the classic setup for **VLAN hopping by double-tagging**: an attacker on VLAN 1 sends a frame with two 802.1Q tags; the first is stripped by the trunk and the inner tag is delivered to the attacker's target VLAN. Yersinia and Scapy automate this. (b) The ACL is broken: the second line `permit ip any any` matches before the final deny and overrides the carefully scoped Modbus rule – effectively the ACL permits everything. The deny-by-default has been undone by the catch-all permit. (c) Therefore RDP (3389) from HMI VLAN 20 into PLC VLAN 10, SMB (445) into the engineering workstation, ICMP sweeps, and the management VLAN 99 are all reachable. Compounding this, the VLAN-hopping primitive means an attacker on the corporate-side trunked VLAN 1 can land directly in VLAN 10 or 99 without traversing the ACL at all. *Rubric: must name double-tagging* and *the catch-all permit; identifying any two concrete forbidden flows is enough.*

Solution

Exercise 3.6 – Substation Time Sync. Three failure modes: (1) *Sequence-of-events inversion:* two protection events 30 ms apart may be logged in the wrong order, so the post-mortem blames the wrong relay. (2) *IEC 61850 GOOSE quality flags:* subscribers reject messages whose timestamp drifts beyond the configured window; trips can be missed or duplicated. (3) *Compliance/forensic:* regulators (NERC CIP-007 in NA, equivalent in EU under NIS2/IEC 62443) require time-aligned logs for incident reports; 50 ms skew invalidates the evidentiary chain.
Fix: deploy IEEE 1588v2 PTP with a GPS-disciplined grandmaster (e.g. Meinberg LANTIME or Hirschmann RSP30 with PTP module) and a holdover oscillator. Every substation switch on the GOOSE/SV path must be a PTP *transparent* or *boundary* clock (Cisco IE-4000/IE-5000, Hirschmann RSP, Moxa EDS-G500E) so residence-time correction is applied in hardware. NTP remains acceptable at L3 (SCADA server, historian, engineering workstation) where millisecond accuracy is plenty; it is not acceptable on the process bus. *Rubric: at least two distinct failure modes (forensic, protection, compliance) and a PTP fix that mentions hardware time-stamping in the switches and a disciplined grandmaster.*

Solution

Exercise 3.7 – Wi-Fi on the Plant Floor. A defensible position is "under conditions". The SSID terminates at a dedicated wireless segment in the iDMZ, never directly on the L2 production VLAN; the WLAN controller (Cisco 9800, Aruba 7200, or an OT-rugged Hirschmann BAT867) sits in the iDMZ behind a stateful firewall. Authentication is EAP-TLS with per-device certificates issued by an internal CA; PSK is rejected because rotation is impractical and a leaked PSK pivots every device at once. Closed loops are *not* run over Wi-Fi: tablets carry read-mostly HMI views with write actions limited to acknowledgements and gated by a second factor on the PLC side. Real-time interlocks and safety functions remain wired. Rollback: continuous WIDS (Cisco CleanAir, Aruba RFProtect) detects rogue or evil-twin APs; a documented playbook isolates the affected SSID, revokes the certificate set, and reverts to wired tablets within the shift. Vendor option: Cisco Catalyst IW9165 for hazardous-area coverage, or Moxa AWK-3252A for IP67 line-side mounting. *Rubric: the answer must address segregation, auth, what loops are out of scope, and a rollback story. A flat "no" or flat "yes" without conditions loses marks.*

Solution

Exercise 3.8 – CISA AA22-103A Architecture Controls. PIPEDREAM/INCONTROLLER targets Schneider Modicon (Modbus/UMAS), OMRON Sysmac (FINS), and OPC UA servers; the toolkit assumes the attacker already has L3 access. Architecture controls that raise cost:

1. *iDMZ broker for all inbound L4–L1 traffic.* Forces the attacker through a jump host with MFA before they ever see UMAS/FINS/OPC UA endpoints.
2. *Industrial firewall with protocol-aware allowlist* (Tofino, Cisco ISA-3000, Fortinet OT-aware policy). Blocks the specific UMAS function codes the tool needs to download logic, even if TCP/502 is open.
3. *Per-line micro-segmentation* (VLAN + L3 ACL, ideally enforced at a Phoenix Contact mGuard per cell). Contains lateral movement so one compromised cell does not surrender every Modicon in the plant.
4. *Read-only TAP feeding a Claroty or Nozomi sensor* on the L2/L3 boundary. Detects FINS/UMAS reconnaissance and the OPC UA Discovery sweeps the toolkit performs.
5. *Egress filtering and a data diode for telemetry out, no path in.* Prevents C2 callbacks from the engineering workstation that the toolkit otherwise uses as a foothold.

Rubric: each control must map to a layer/zone and target a specific toolkit behaviour (protocol parsing, lateral move, C2). Generic "patch everything" answers are not architecture controls.

Solution

Exercise 3.9 – Bandwidth Floor. Per poll: request ≈ 12 B Modbus + 40 B TCP/IP = 52 B; response ≈ 200 B Modbus + 40 B TCP/IP = 240 B. Round trip = 292 B = 2336 b. With 50 PLCs at 1 Hz: $50 \times 2336 \approx 116.8$ kbit/s. **Poll floor ≈ 117 kbit/s** (call it 0.12 Mbit/s).
The IDS mirror copies both ingress and egress of the SCADA uplink, so the floor is twice the unidirectional traffic, ≈ 234 kbit/s, plus any broadcast/multicast on the mirrored port. **Mirror floor ≈ 0.25 Mbit/s**.
Practical floor is higher because (i) Ethernet framing adds 18–26 B per packet (preamble, FCS, IFG, optional VLAN tag), (ii) PLCs answer with diagnostic replies and keep-alives, (iii) operator HMI polls and engineering-workstation traffic share the link. A 100 Mbit/s SPAN port still drops frames when total mirrored traffic spikes (e.g. during a firmware push or an ARP storm), because SPAN is best-effort on the switch CPU and is the first thing dropped under load – a hardware TAP avoids this entirely. *Rubric: correct numbers within ±20%; bidirectional mirror; at least one realistic reason the practical floor is higher.*

Solution

Exercise 3.10 – Zones and Conduits. Sample zoning for the bottling plant: **Z1 Safety** (SIS, SL-T 4), **Z2 Process Control** (PLCs + Hirschmann fabric, SL-T 3), **Z3 Supervisory** (HMI, SCADA, engineering workstation, SL-T 3), **Z4 Plant Operations** (live historian, MES, AV, SL-T 3), **Z5 iDMZ** (replica historian, WSUS, mGuard jump host, wireless aggregation, SL-T 2), **Z6 Enterprise** (SAP, M365, SL-T 1).
Selected conduits:

- C1 Z2→Z3: OPC UA on TCP/4840, push from PLCs to HMI/SCADA, enforced by Tofino in transparent mode in front of each PLC.
- C2 Z4→Z5: historian replication, OPC UA or vendor connector, push-only, enforced by Owl or Waterfall diode.
- C3 Z5→Z6: HTTPS pull from SAP BI to replica historian, enforced by Fortinet/Palo Alto stateful firewall.
- C4 Z6→Z5: vendor RDP into the mGuard jump host, MFA-bound and time-bound, enforced by Cisco ISA-3000.
- C5 Z2→Z1: hard-wired dry contacts only, no Ethernet, no IP conduit.

Data diode is right for C2: the flow is genuinely one-way and the live historian's integrity backs every BI report – a hardware-enforced no-return path is auditable in a way that a firewall rule is not. Stateful firewall is right for C4: vendor remote access is inherently interactive and time-bounded, the workload does not fit a diode, and a deny-by-default ruleset with MFA and session recording captures the residual risk. *Rubric: at least four zones with sensible SL-T values, conduits with direction and enforcement device, plus a defensible diode-vs-firewall justification rooted in the conduit's directionality.*